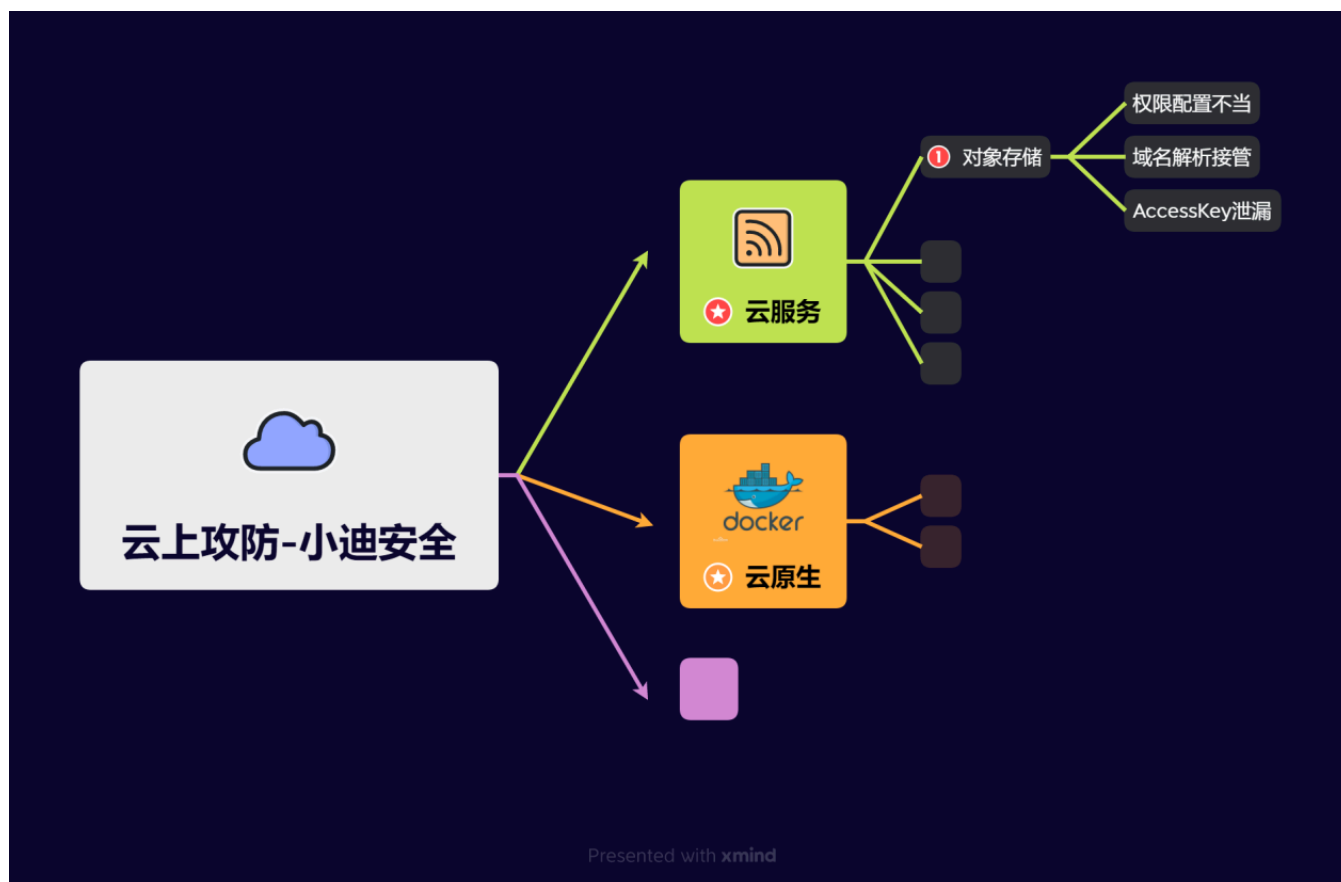


# Day93 云上攻防-云服务篇&对象存储&Bucket桶 &任意上传&域名接管&AccessKey泄漏



## 1.知识点

- 1、云服务 - 对象存储 - 权限配置不当
- 2、云服务 - 对象存储 - 域名解析接管
- 3、云服务 - 对象存储 - AccessKey泄漏

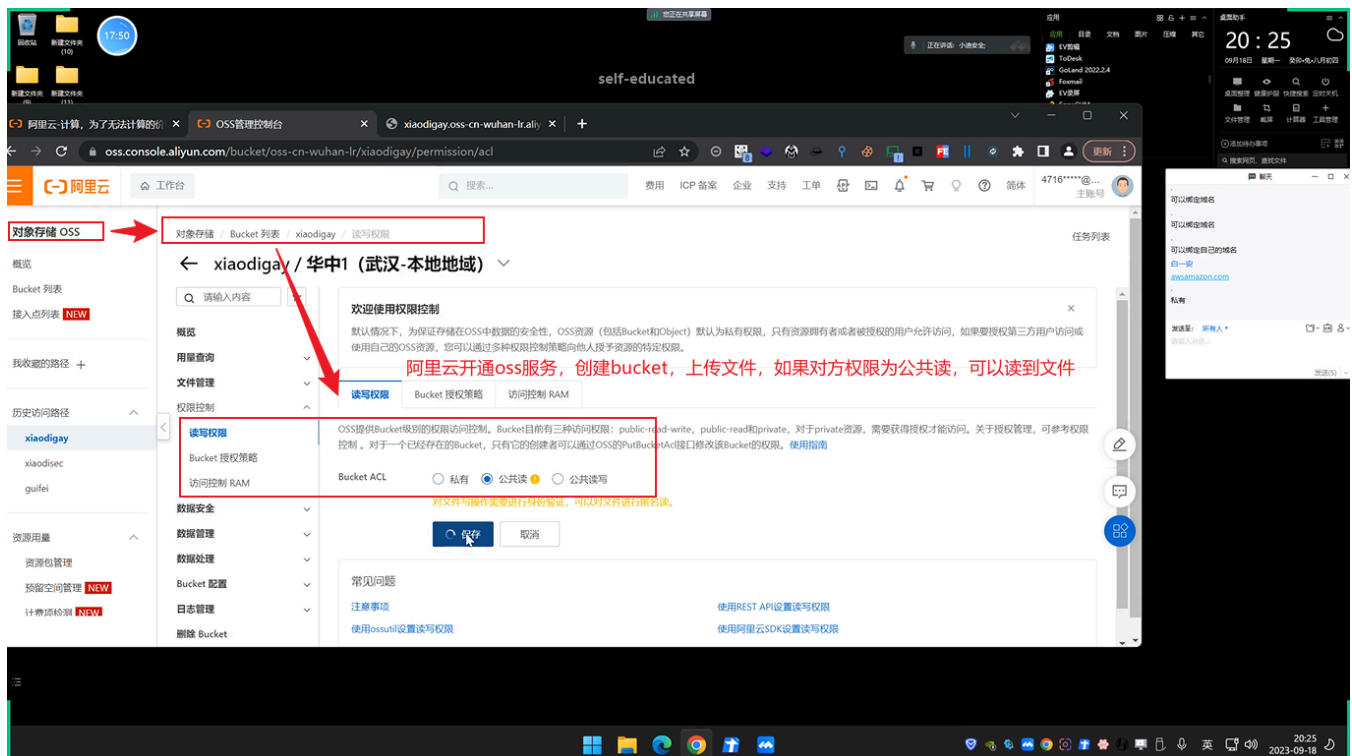
## 2.演示案例

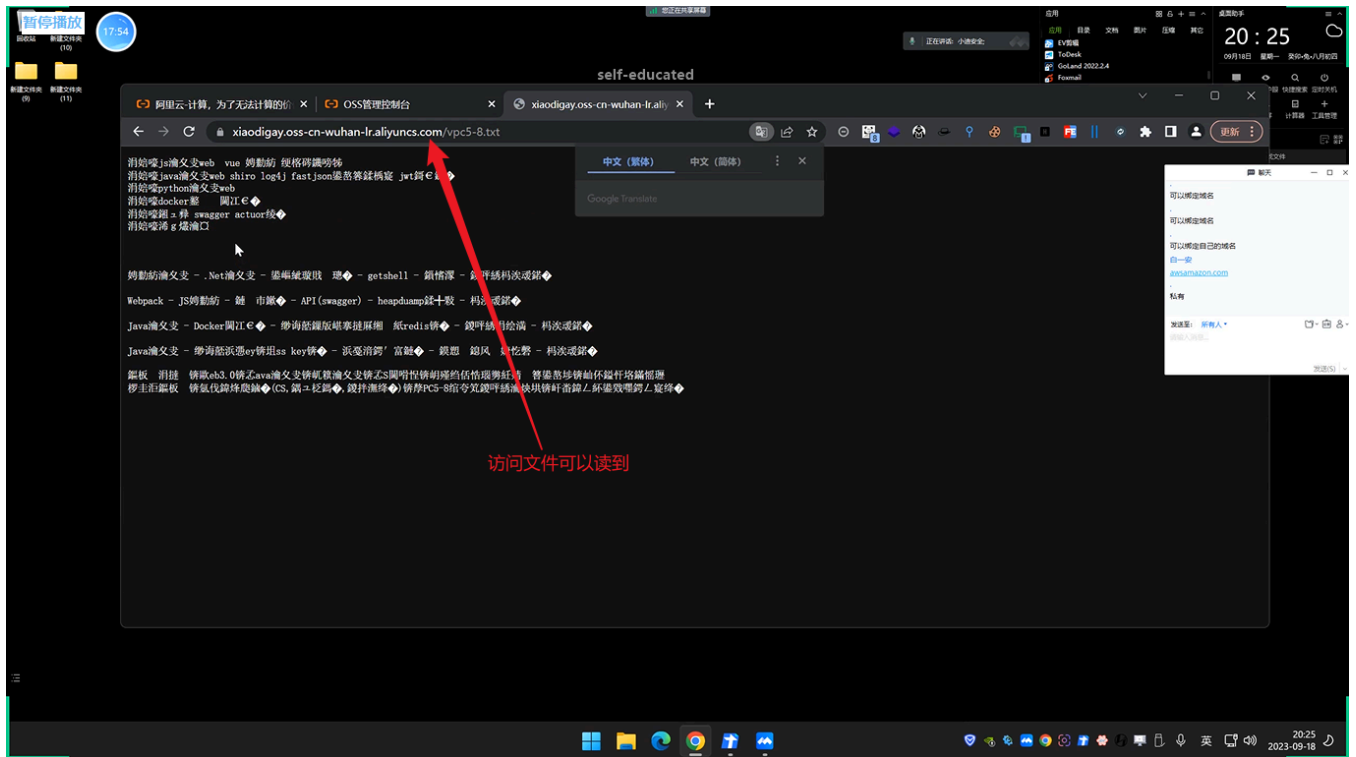
- 1 云服务，顾名思义就是云上服务，在云厂商上购买的产品服务。
- 2 国内有阿里云、腾讯云、华为云、天翼云、Ucloud、金山云等，
- 3 国外有亚马逊的AWS、Google的GCP、微软的Azure，IBM云等。
- 4
- 5 各个云厂商对云服务的叫法都不统一，这里统一以AWS为例。
- 6 S3 对象存储Simple Storage Service，简单的说就是一个类似网盘的东西
- 7 EC2 即弹性计算服务Elastic Compute Cloud，简单的说就是在云上的一台虚拟机。
- 8 RDS 云数据库Relational Database Service，简单的说就是云上的一个数据库。
- 9 IAM 身份和访问管理Identity and Access Management，简单的说就是云控制台上的一套身份管理服务，可以用来管理每个子账号的权限。
- 10
- 11 #对象存储各大云名词：
- 12 阿里云：OSS 腾讯云：COS 华为云：OBS
- 13 谷歌云：GCS 微软云：Blob 亚马逊云：S3

### 2.1 云服务-对象存储-权限配置不当

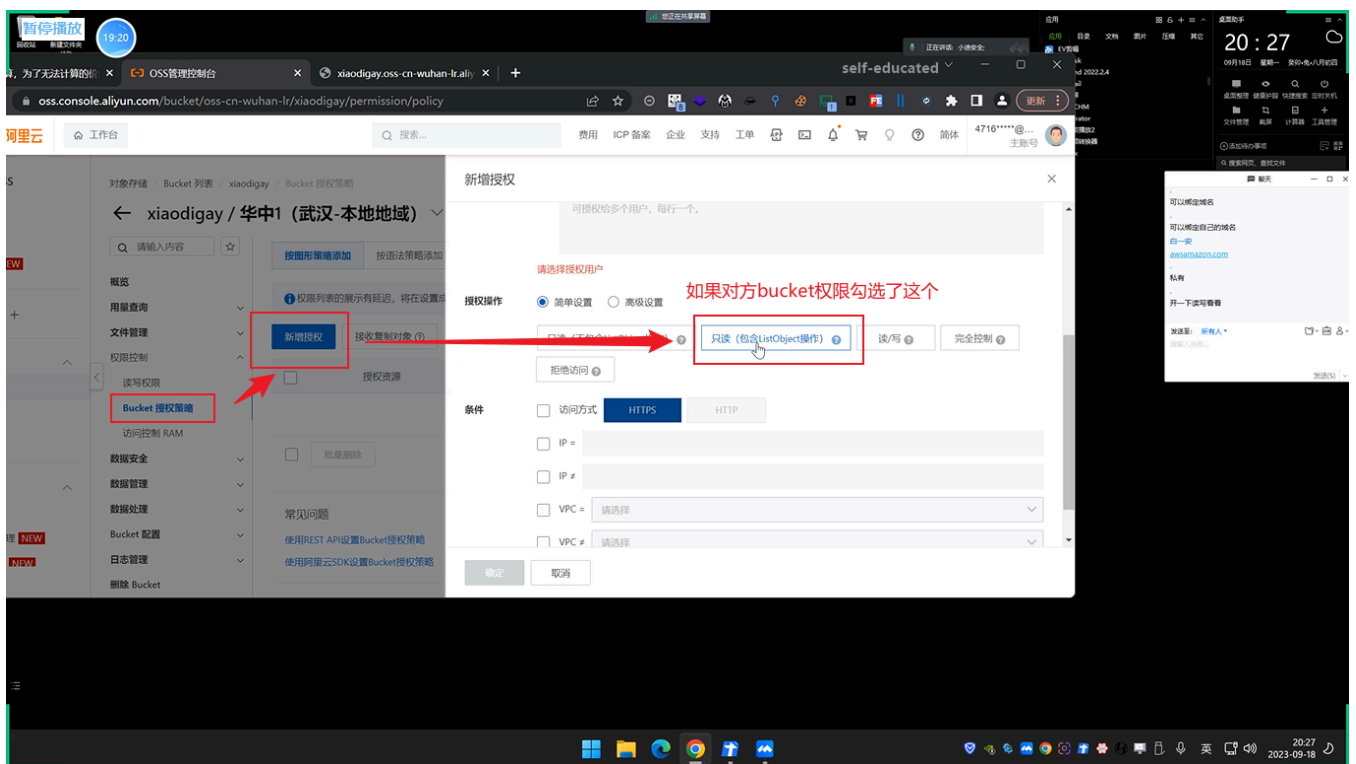
- 1 1、权限配置错误
- 2 -公共读或公共读写：可完整访问但不显示完整结构
- 3 -权限Bucket授权策略：设置ListObject显示完整结构
- 4 -权限Bucket读写权限：公共读写直接PUT文件任意的上传

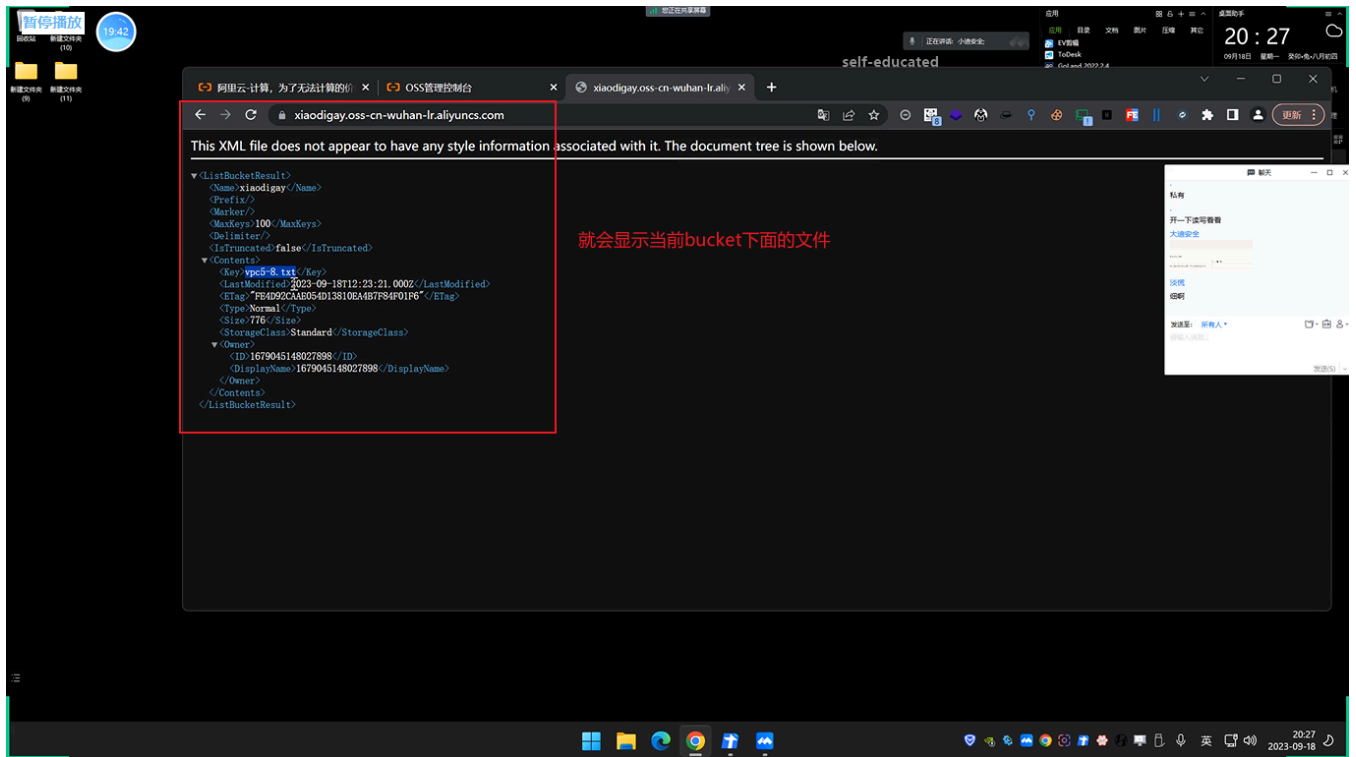
#### 2.1.1 公共读或公共读写



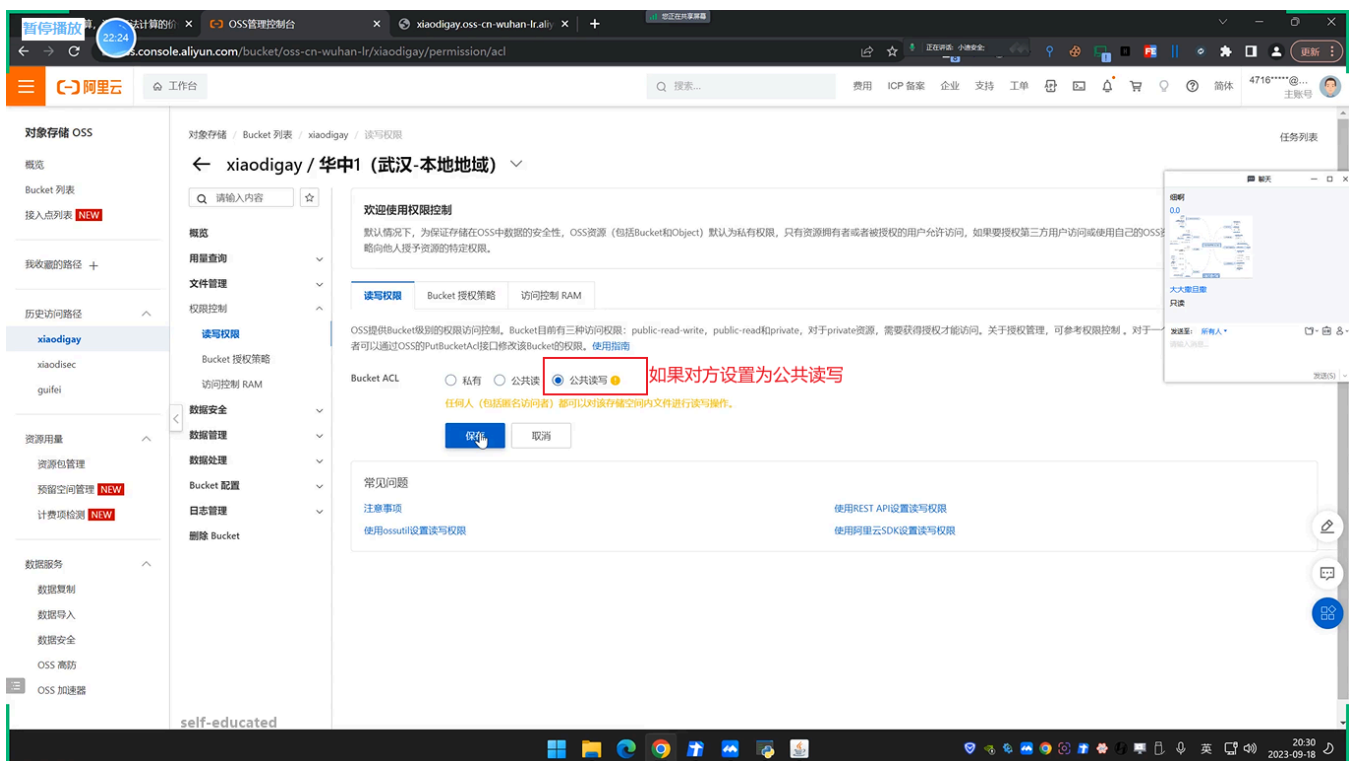


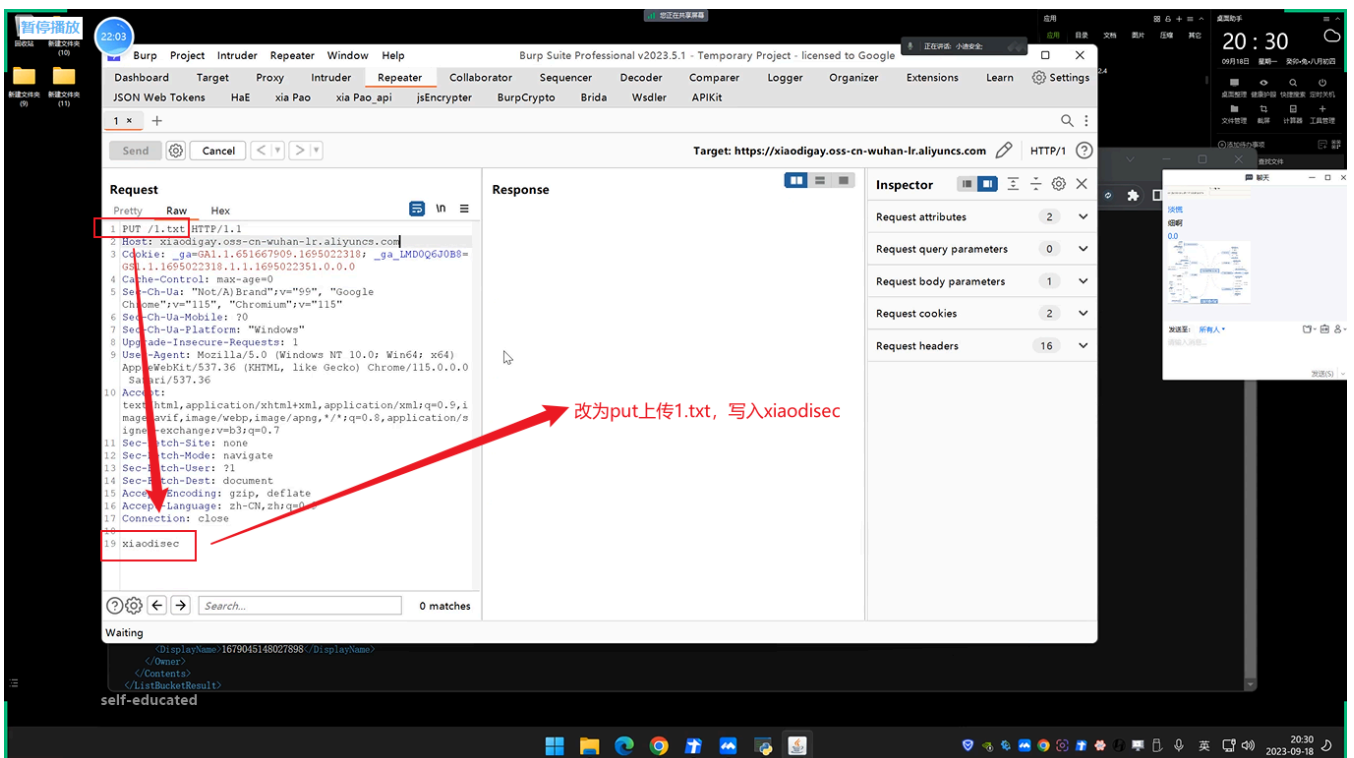
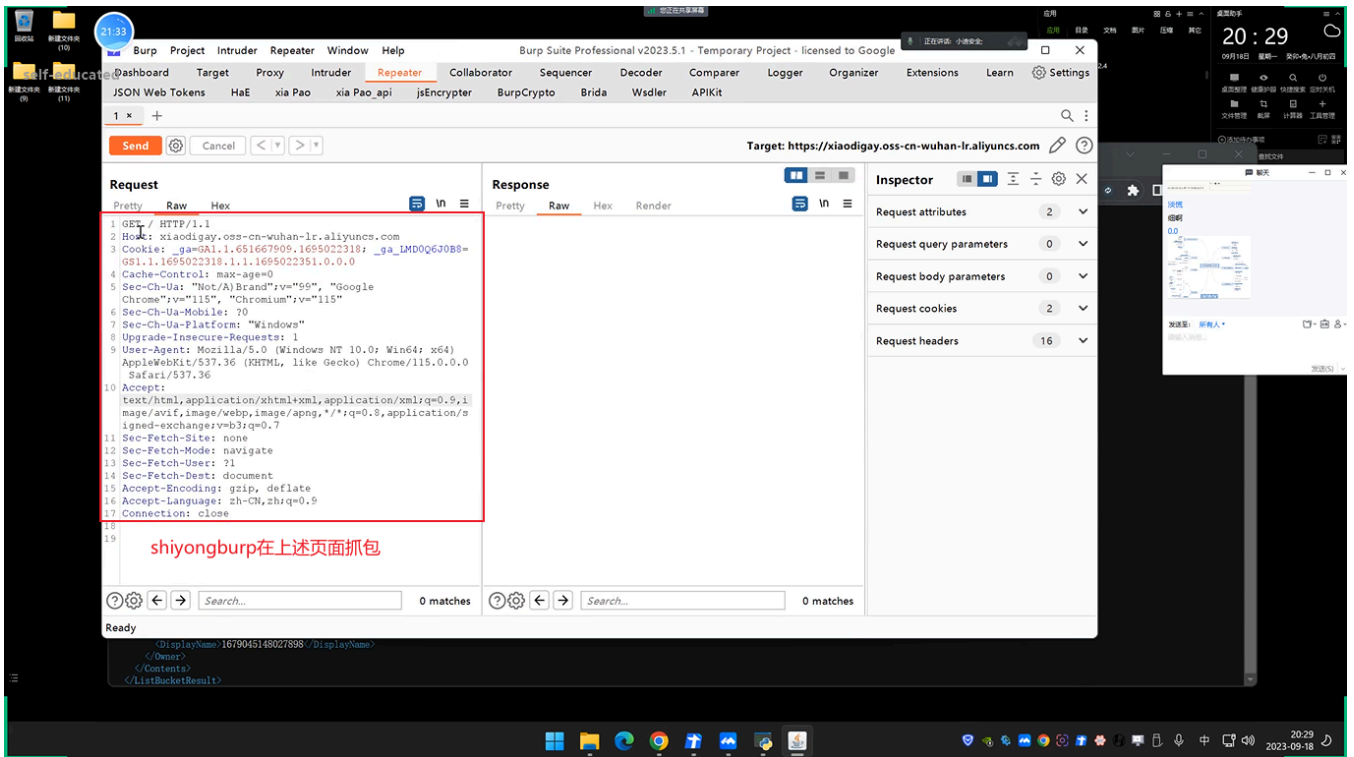
## 2.1.2 权限Bucket授权策略

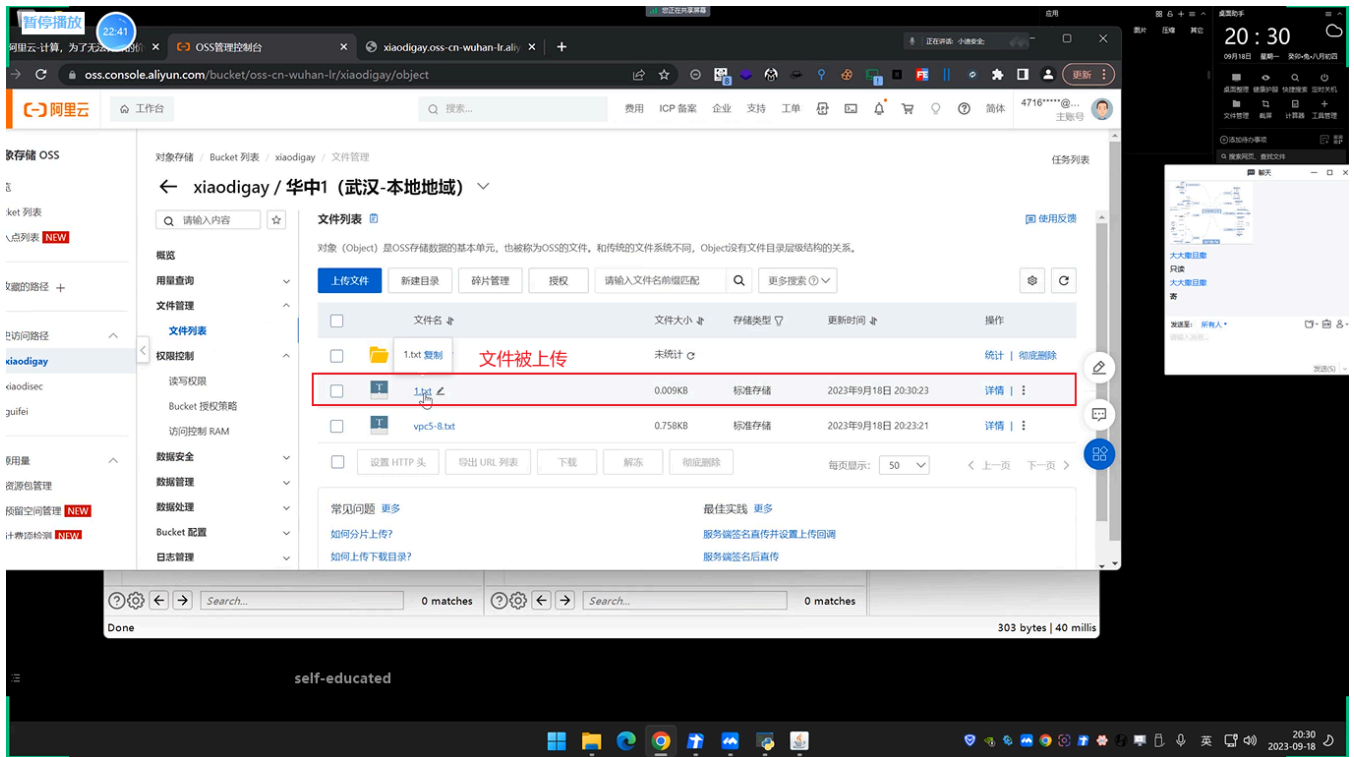




### 2.1.3 权限Bucket读写权限

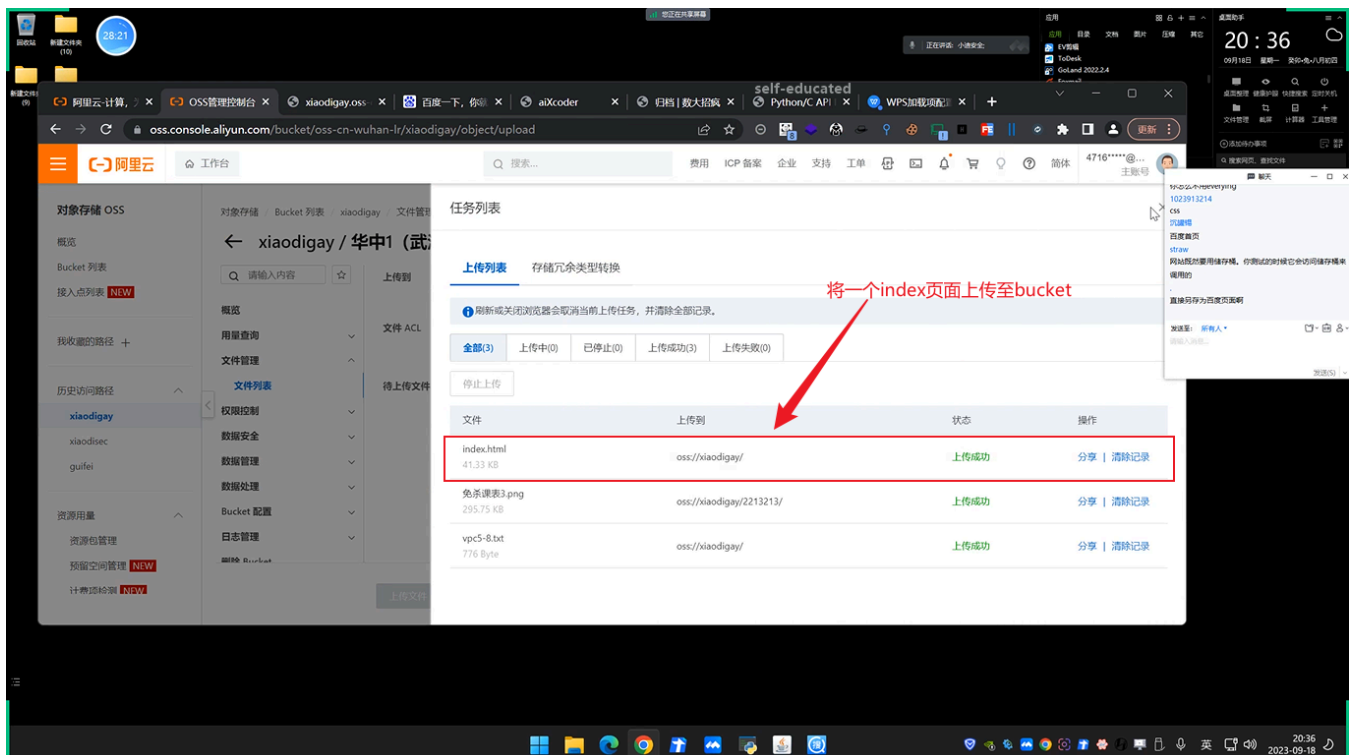


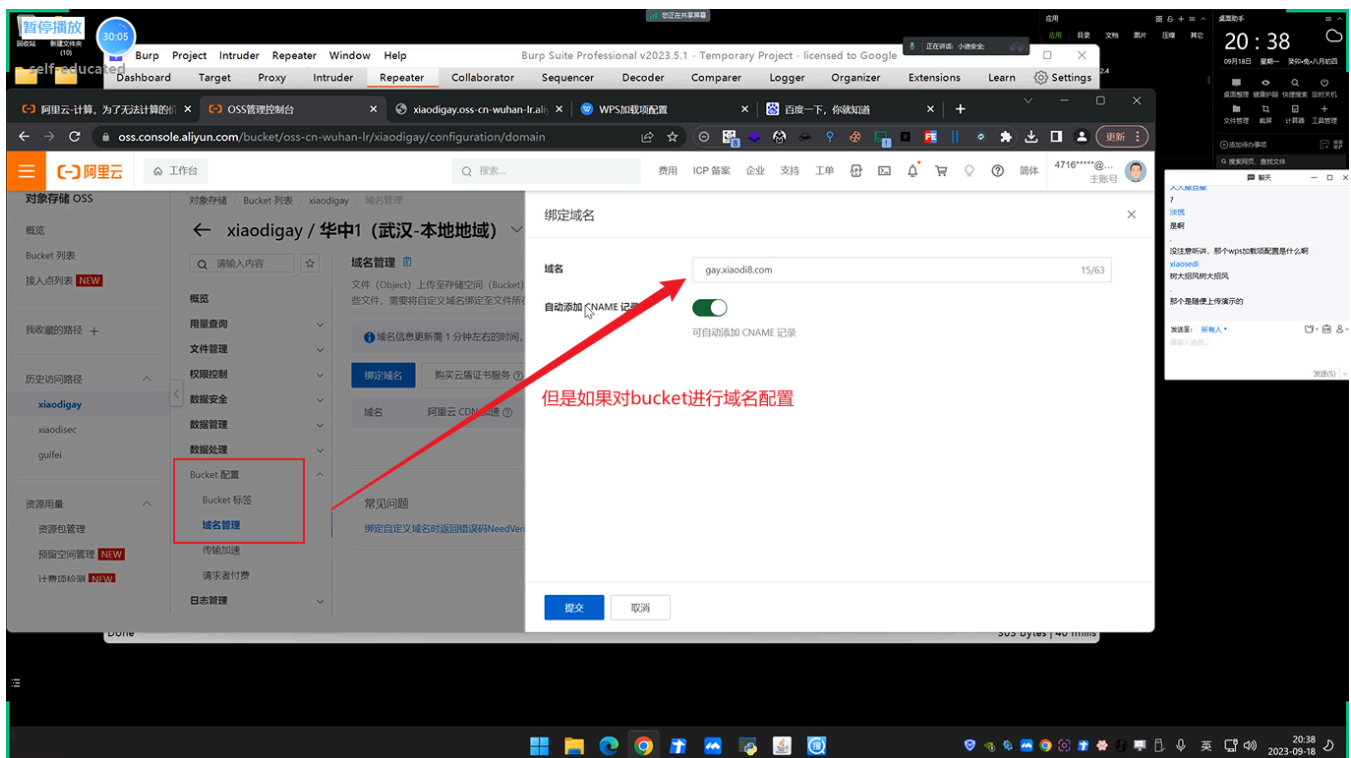
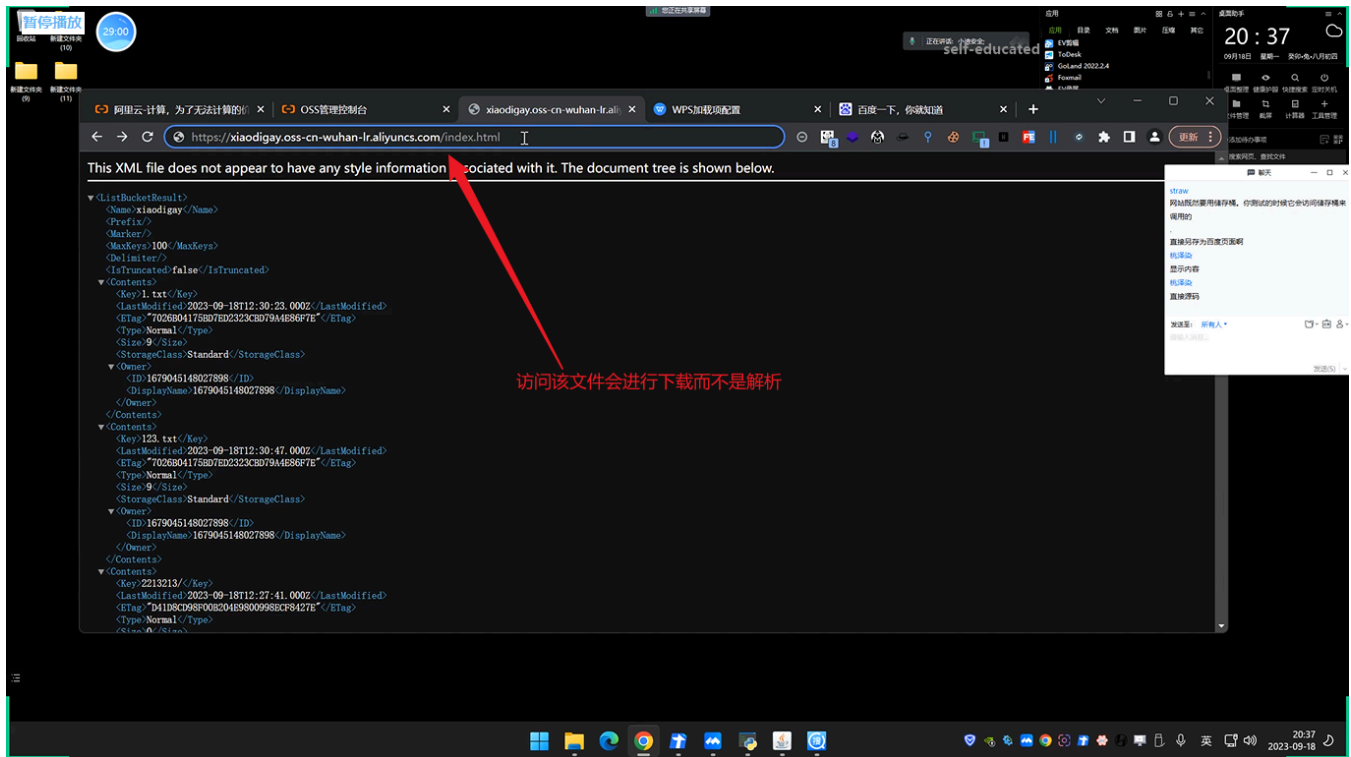




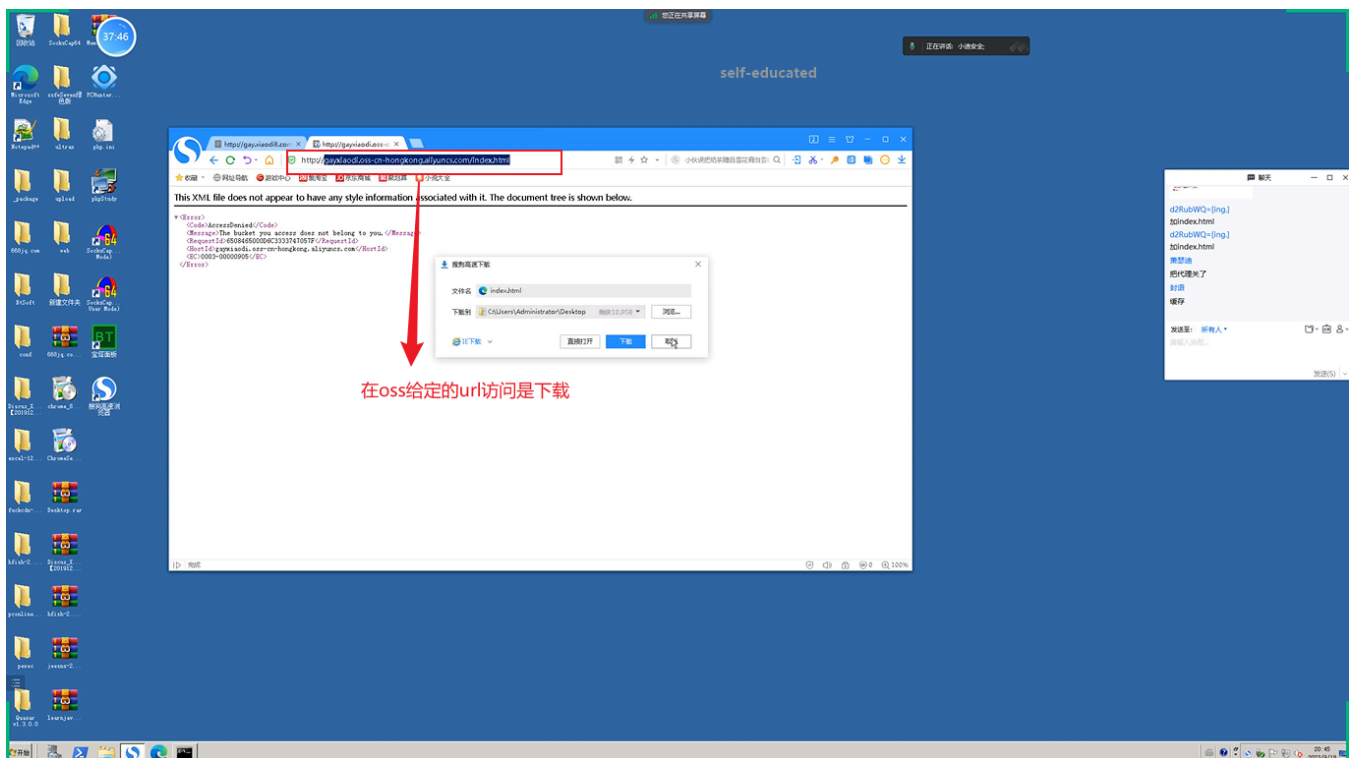
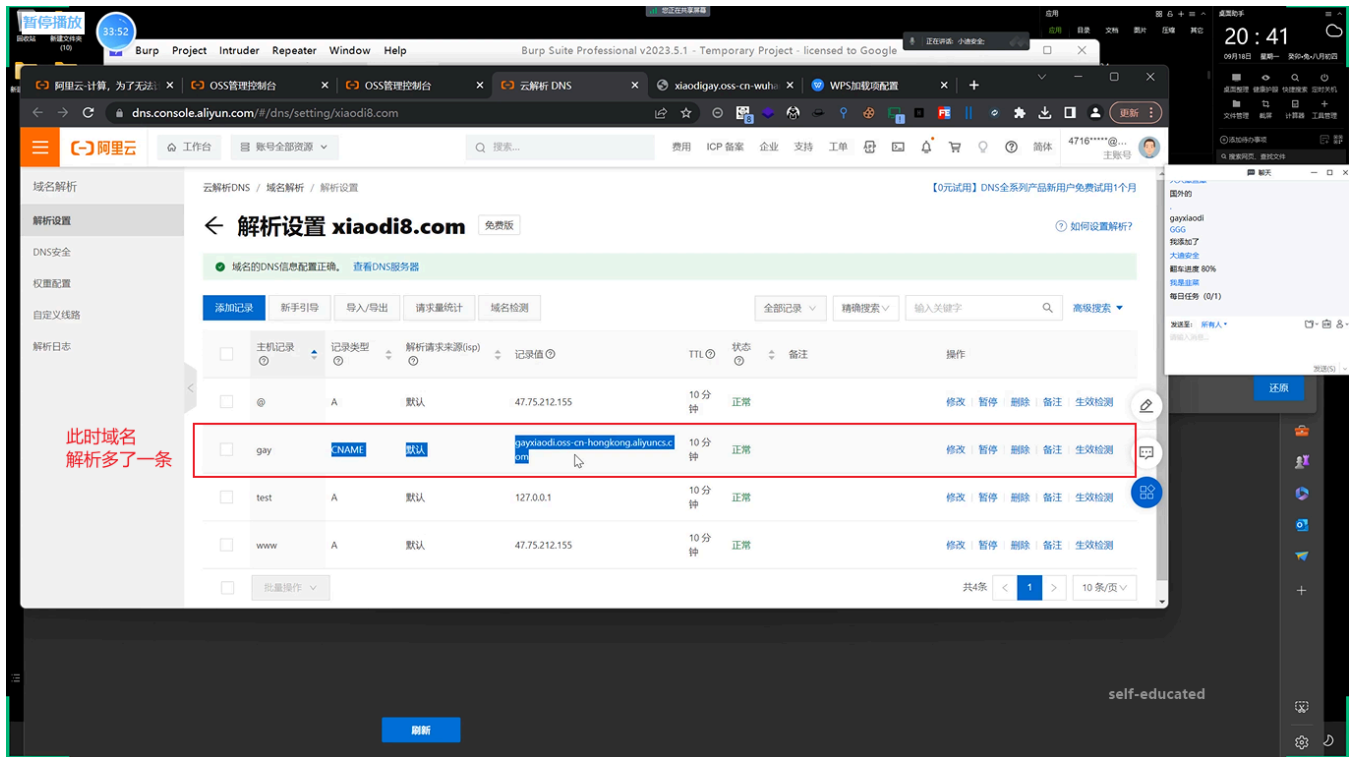
## 2.2 云服务-对象存储-域名解析接管

- 1 2、域名解析Bucket接管：
- 2 Bucket存储桶绑定域名后，当存储桶被删除而域名解析未删除，可以尝试接管！
- 3 当Bucket显示NoSuchBucket说明是可以接管的，如果显示AccessDenied则不行。

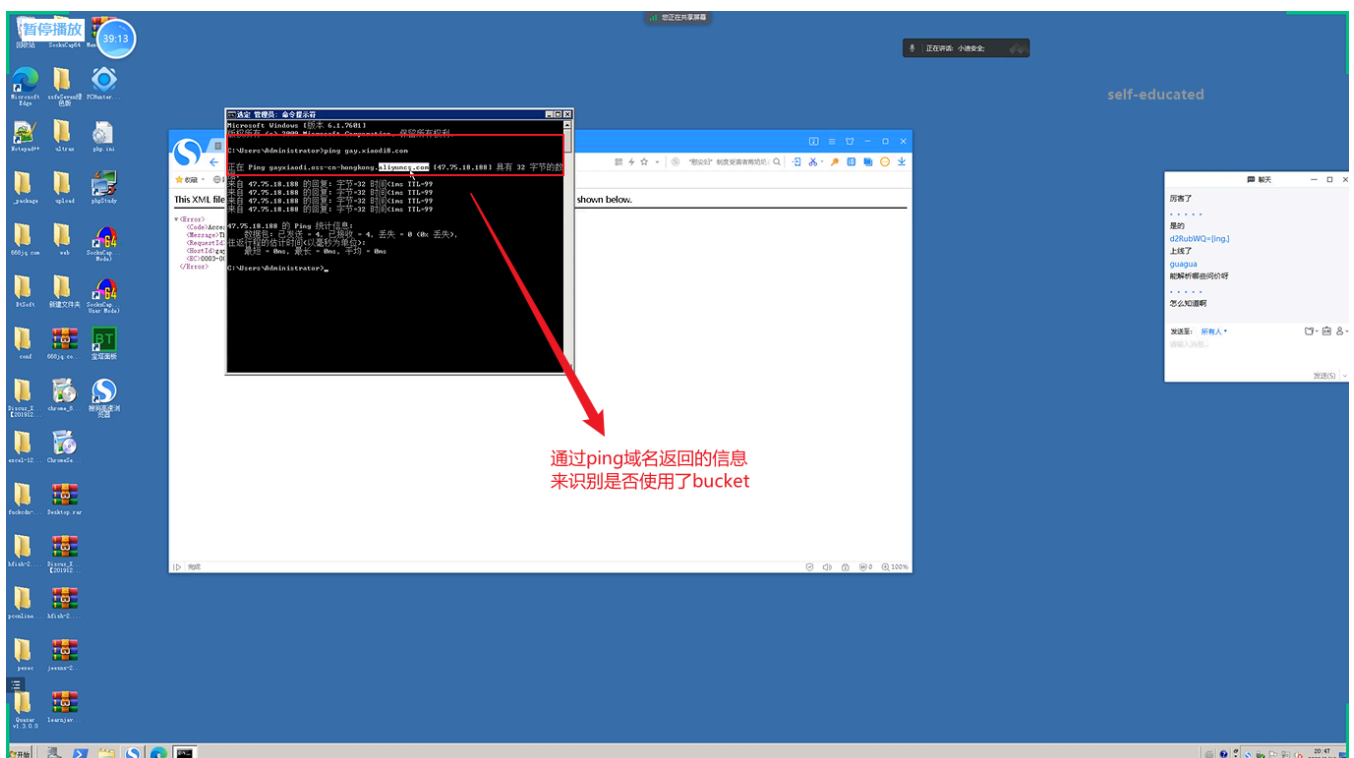
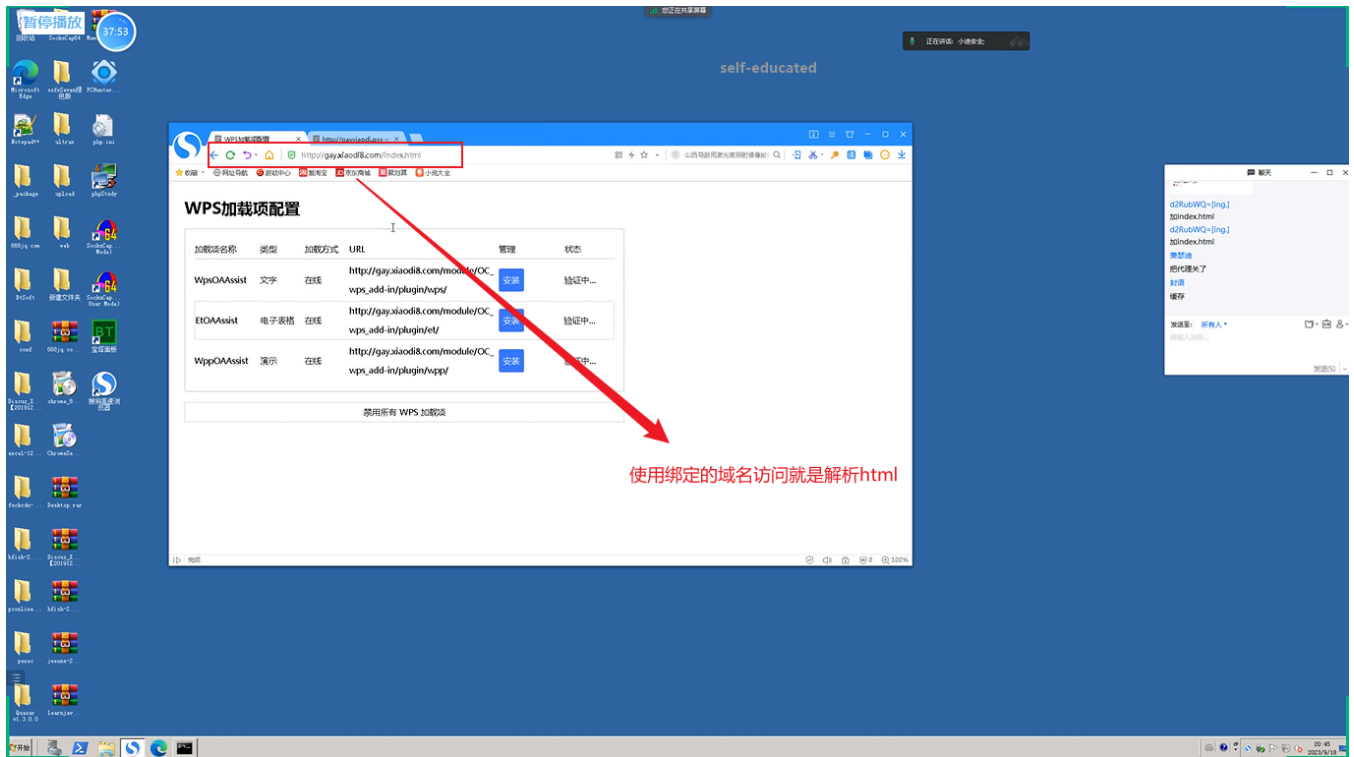


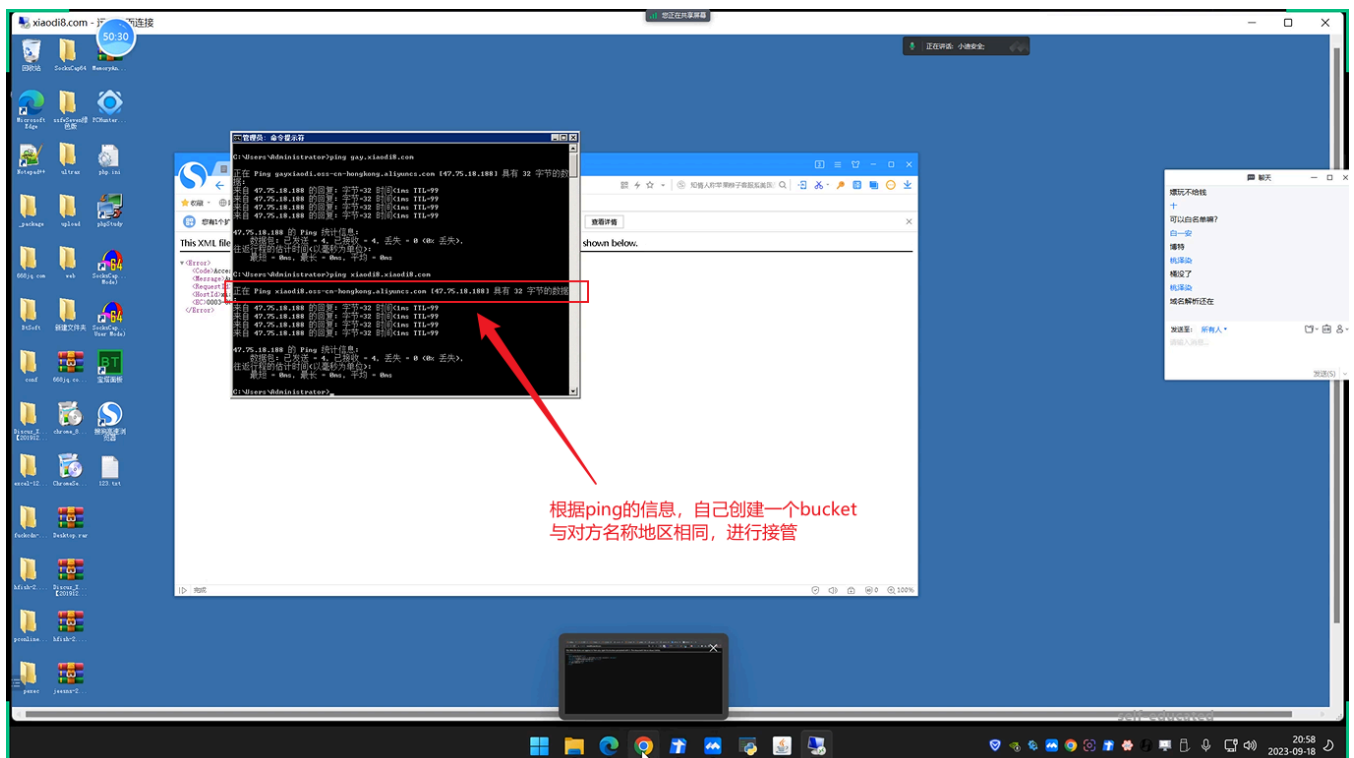
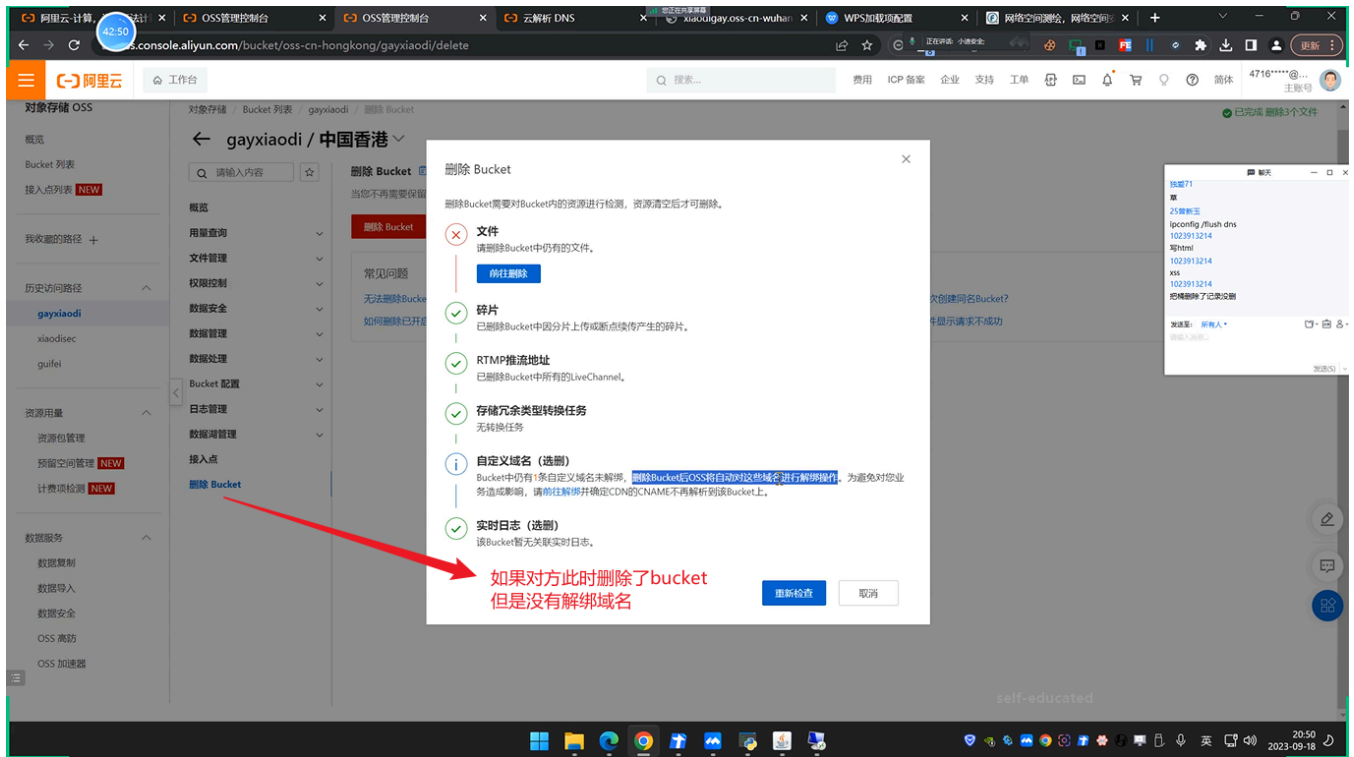












以后对方上传和解析的资源都会上传到自己的bucket中

## 2.3 云服务-对象存储-AccessKey泄漏

- 1 3、AccessKeyId, SecretAccessKey泄漏:
- 2 -APP, 小程序, JS中泄漏导致
- 3 AccessKey标识特征整理-查找
- 4 <https://wiki.teamssix.com/CloudService/more/>

